Kristiania University College

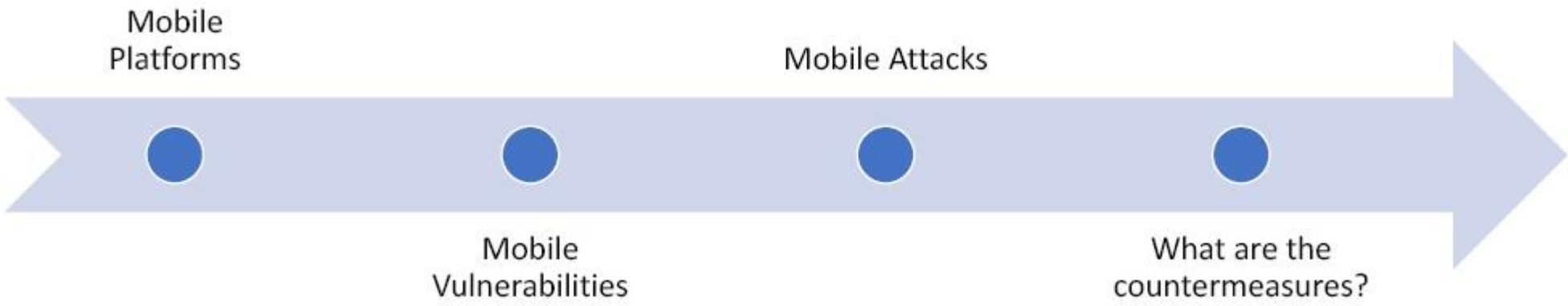
# Today's topics

Mobile security

- Countermeasures
- Technical controls
- Security principles

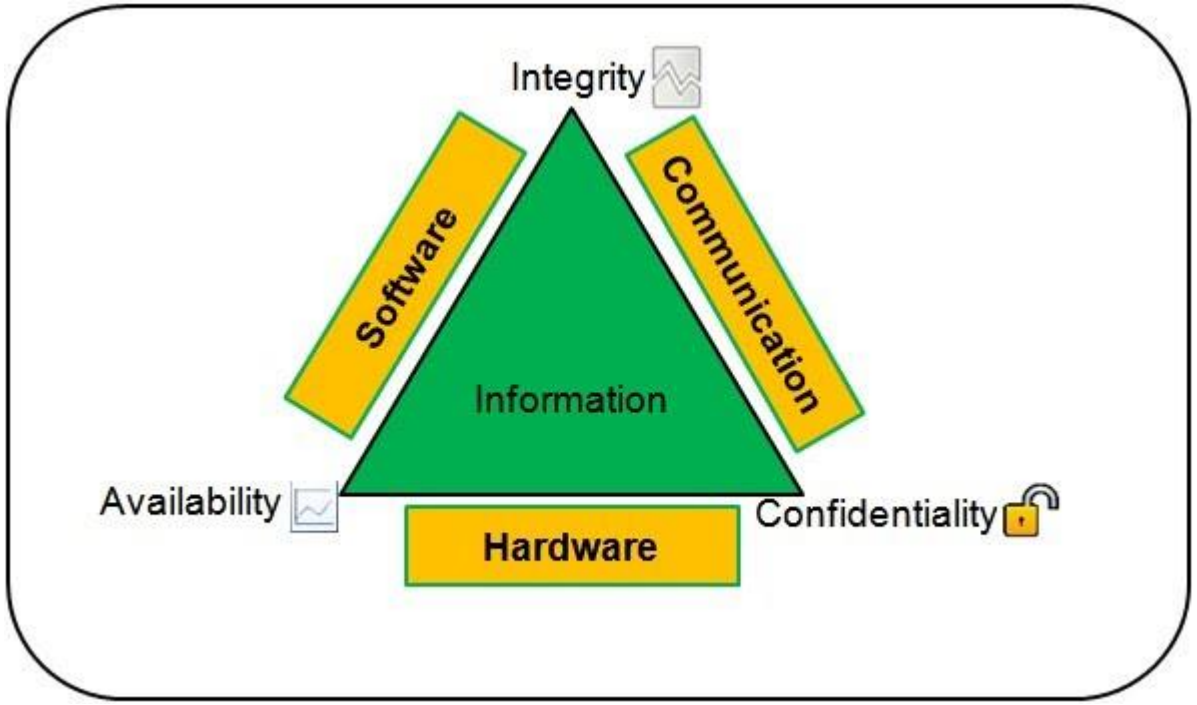
# Mobile security countermeasures

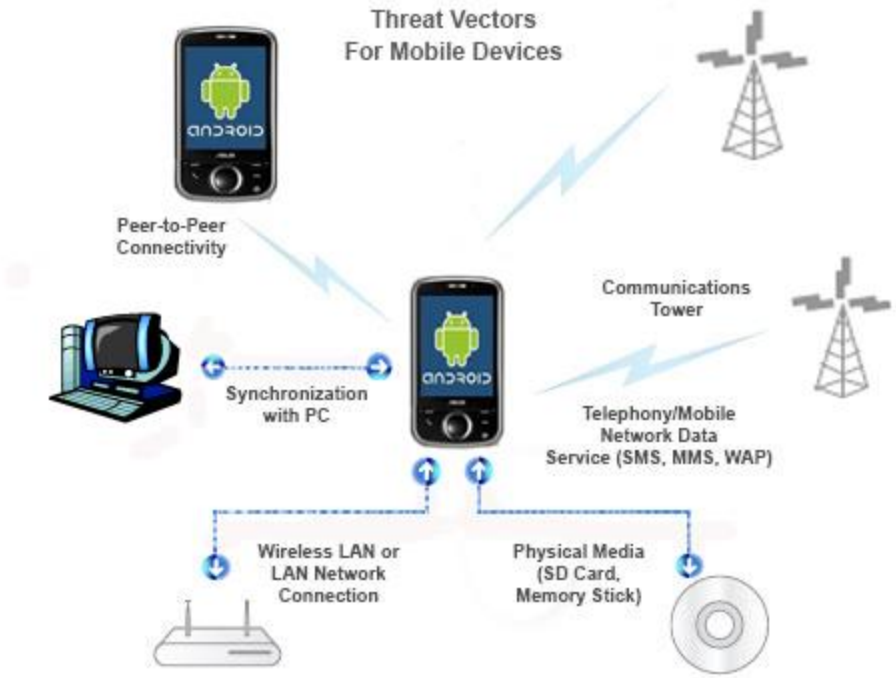
- Mobile security **countermeasures** are actions, devices, procedures, techniques, or other measures that reduce the vulnerability of an information system.



# Countermeasures …

- **Countermeasures** are prescribed to meet the **security requirements or goals**(i.e., confidentiality, integrity, and availability) specified for the mobile platform and other systems it gets connected to.

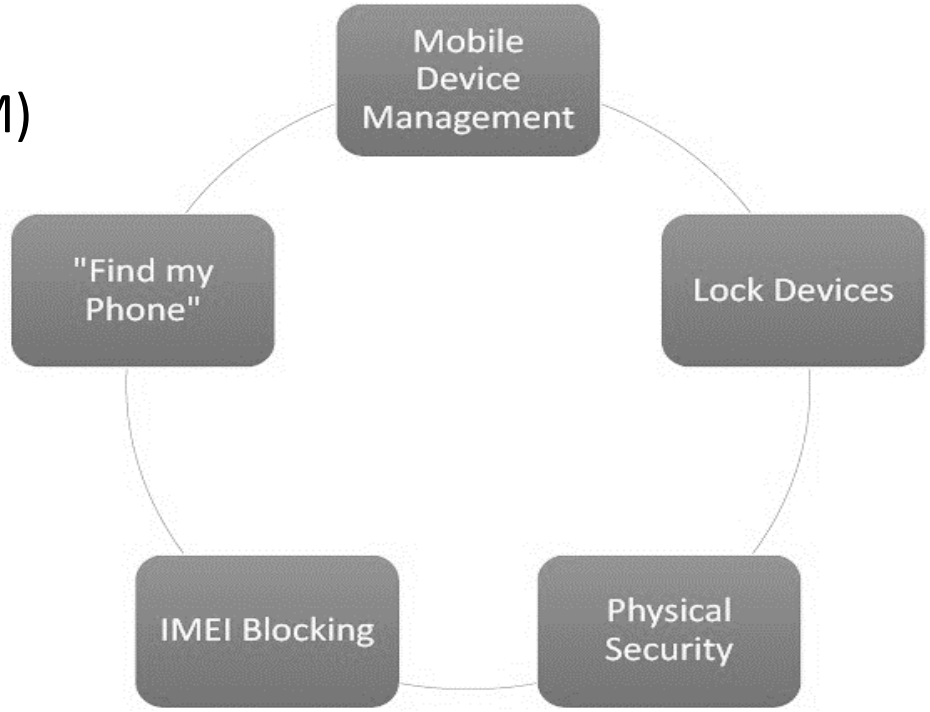


# Countermeasures …

Example of countermeasures

- Mobile device management (MDM)
- Lock devices
- IMEI blocking
- Physical security
- “Find my Phone”



# Countermeasures …

Example of countermeasures …

- **Mobile device management-** use **software and hardware to control** mobile access to an organization's data and services.
- **Lock devices-** use PIN code, and lock pattern- as it is better than leaving open.
- **Physical security-** is vital as the device is always with the person and has **entire digital identity** of the owner which can prove to be very **unsafe if** lost or stolen.
- "**Find my Phone**"- is an app in many mobile platforms (e.g., Android) where one can register the device, talk to back-end service and **get real time info about the device**.

# Countermeasures …

Example of countermeasures … IMEI Blocking

- **IMEI** (**International Mobile Equipment Identity**) is a 15 digits unique ID or serial number that **all mobile phones have**.
- It is found on the silver **sticker on the back of your phone**, under the battery pack, or on the box your phone came in OR it **can be found by dialing *#06#**.
- **IMEI Blocking**- enables one to **ask the ISP to block**, if a device gets lost or stolen.



# Mobile Security Technical Controls

Kristiania University College

Passwords, passphrases and biometrics:

- **Protect your device** with proper handling of password credentials (password or passphrase) and **enable auto-lock**.
- Choose the **strongest alphanumeric password** that your device can support.

  Good passwords are **short, easy to remember** (15-character).

  Use **capital letter**, **a number**, **a substituted word**, **a misspelt word** and **a special**.

  **Example** of such password is “Back2dafewture!”.
- Modern mobile devices have **biometric locks** to provide more secure access control and are a supplementary or alternate control.

# Technical Controls …

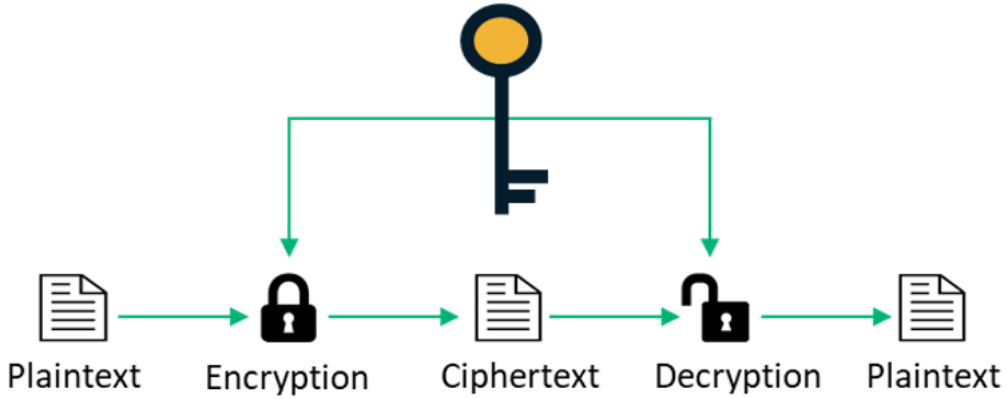
Encryption:

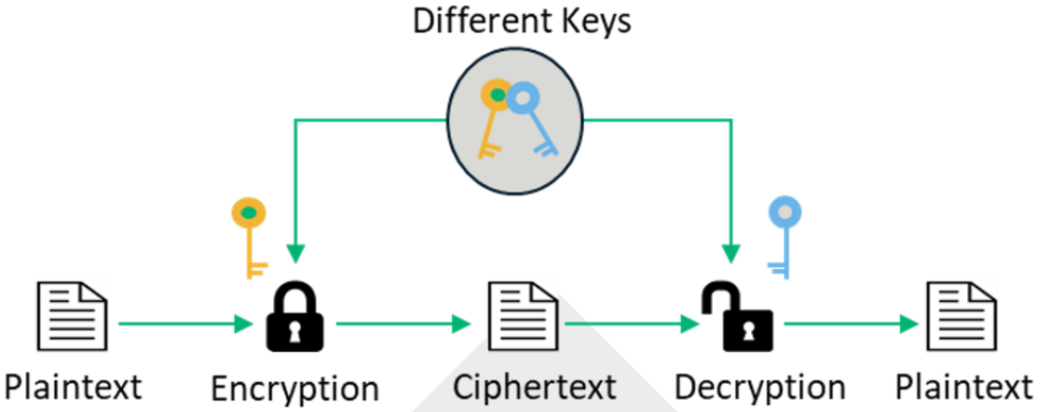
- It is a method of converting information into **secret code** that hides its true meaning.
- The converted secret code is called **ciphertext**.
- The science of encrypting and decrypting information is called **cryptography**.
- **Cryptography** enables secure communication under adversarial behavior.

Categories of cryptography:

- **Symmetric** key cryptography relies on a **shared key** between two parties.
- **Asymmetric** key cryptography uses a **public-private key pair** where one key is used to encrypt and the other to decrypt.
- **Has function** (one-way cryptography has no key since the **plaintext is not recoverable** from the ciphertext.

# Technical Controls …



# Technical Controls …

Code encryption:

- Enables to **maintain system integrity** by providing a facility to detect code integrity violation (e.g., helps to **protect reverse** engineering attack).
- Protects mobile users from information **theft** or **privacy** violation.
- An encrypted code is **decrypted on the device** before loading for execution.

Data encryption:

- User data is stored both **locally** and **in the cloud**.
- Most mobile operating systems provide some form of **full-disk encryption solution**.
- **Cloud storage** enables to back up and provide **multiple-device** support with synchronization.

# Technical Controls …

Types of data stored in the cloud:

- **Contacts list**, browser bookmarks, chat logs
- **Settings and logs**- system and application specific
- **Apps**, content, automated support, documentation, etc.
- **Passwords,** Photos, Game progress

Data encryption in cloud:

- **Key generation** process happens on the client device.
- The **key is encrypted** with user-supplied input and the **data is encrypted** using this key.
- Only the **encryption key** and the **encrypted data** are ever stored in the cloud.
- The data is **decrypted** only after bringing it back to the device.

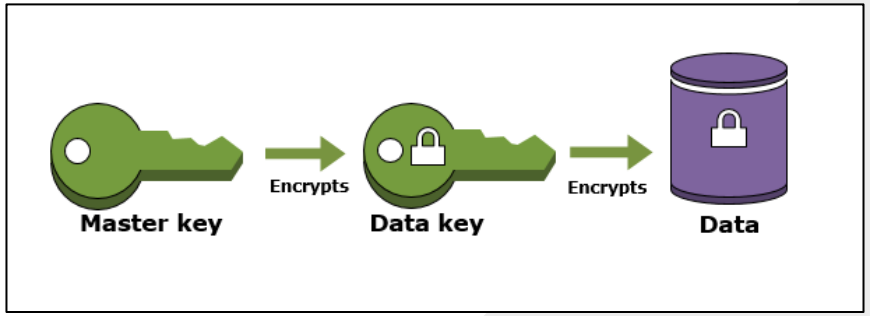
# Technical Controls …

Encryption key management:

- It describes **how cryptographic keys** are generated, protected, managed, and distributed.
- In most cases, the key generation **seed** is the unique device identifier **(UID)** of **mobile device**.
- This **UID cannot be seen** or extracted by anyone including the device manufacturer.

Master key:

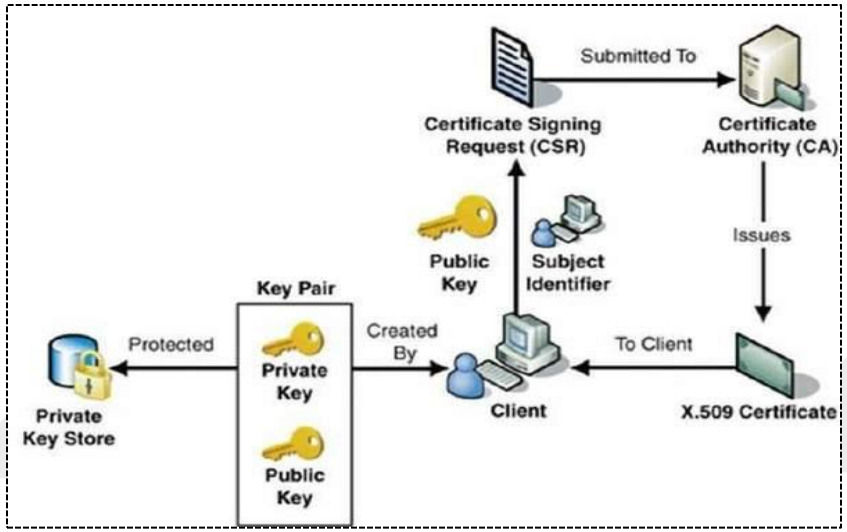
- Master key is **used to encrypt key stores** or other keys including the **data-encrypting key**.
- **User-supplied variable** is utilized to encrypt the master key.
- **For example, a master key** can be created using UID as input.



# Technical Controls …

**Public Key Infrastructure (PKI):**

- It is a **PKC based encryption framework** that protects communications between a server (a website) and client (users).
- It **works** by using two different cryptographic keys: a public key and a private key.

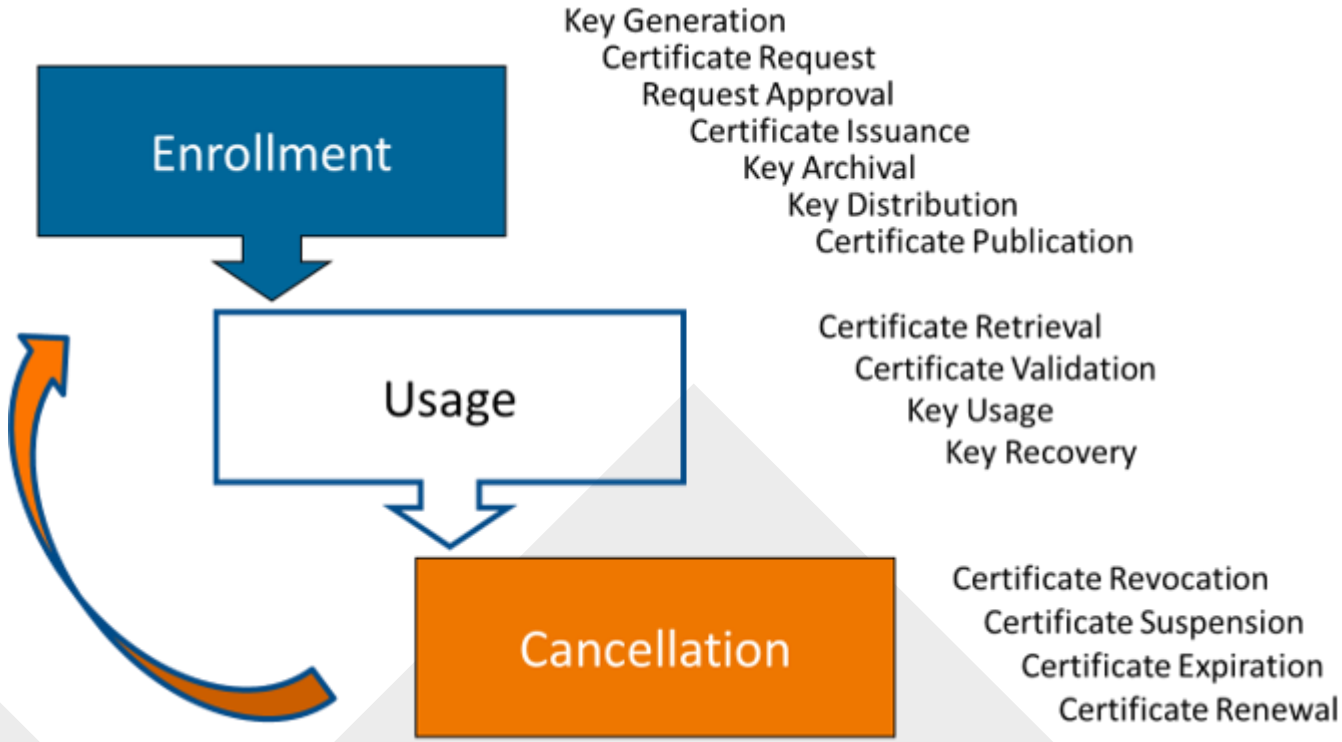





# Technical Controls …

PKI key management:

- **PKI issues certificate** and performs listing of certificates on a Certificate Request List (CRL), in response to a current request.
- **New keys are issued at regular intervals**, such as every year or two, to reduce the exposure from keys that have been unknowingly **compromised**.
- PKI should **restore the keys to the user** in case they **forget** the passwords that protect their private keys or **lose** the keys through a disk crash or virus attack.
- When **employees leave** the company, the network manager **retains the keys** in order to access previously encrypted files and email messages.



# Technical Controls …

Application of PKI :

- Data encryption for **confidentiality**:

  Use key pairs to **encrypt messages** and files for secure e-mail and messaging.
- **Encryption** for **authenticating** people, applications and services, and for **access control**:

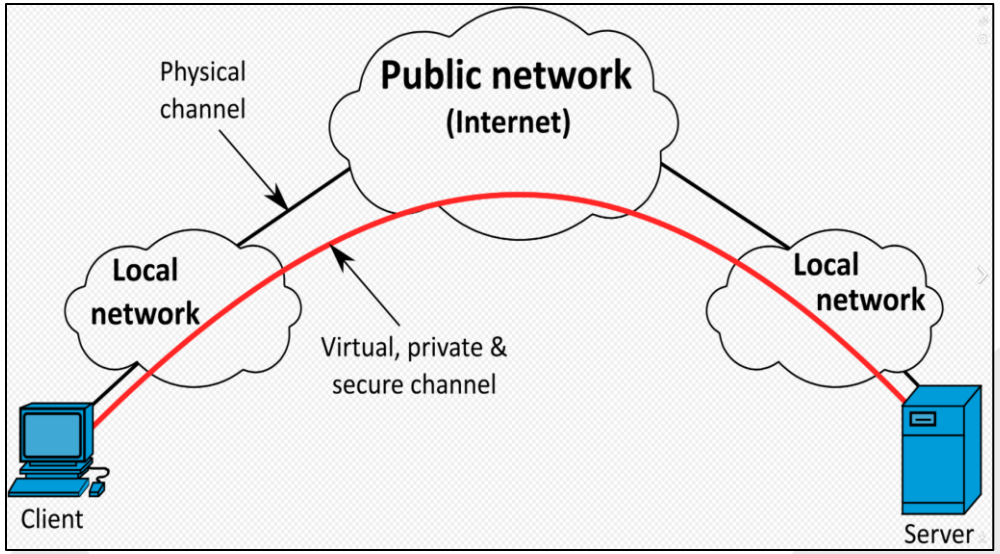
  Browsers and Web servers use **certificates for authentication**(and confidentiality) and for applications like **online banking** and **shopping**.
- **Digital signatures** to provide **non-repudiation** (accountability) and verify **data integrity**.

  Use **digital signatures** to verify the **source** and **integrity** of the content of code and files.

# Technical Controls …

Virtual Private Network (**VPN**):

- **VPN is commonly used by mobile workers** who are unable to guarantee secure connection and yet might need **to access an organization's resources**.
- A properly configured VPN **prevents attackers** from intercepting and modifying traffic, while allowing approved access to internal resources.
- VPN's security utility can be enhanced by deploying **multistep** or multifactor authentication.




Types of VPN:

- **IPsec VPNs is used for point-to-point connections** when network endpoints are known and fixed.
- **SSL VPNs provide secure access through a web browser** and are commonly used by remote workers.
- **Mobile VPNs provide mobile devices with secure access** to network resources and software applications on a network **while moving** from one physical location to another.

# Technical Controls …

User training:

- **User training is even more important** than technical controls.
- **An educated user on a device with poor security is safer than** an uneducated user on a device with "strong" security.

Avoid jailbreaking and rooting:

- **Avoid removing hardware restrictions** (e.g., rooting on Android, and jailbreaking on Apple) on your mobile device in order **to install unapproved third-party** apps or features.
- This can **weaken built-in security protections**, leaving your phone susceptible to malware.

Patching:

- **Patching** is the process by which **software flaws are fixed** and **features improved**.
- It should be noted that jailbreaking/rooting **destroys the possibility of protection using patches.**

# Technical Controls …

Remote track and wipe:

- Remote track and wipe aims to **mitigate the risk of device theft or loss**.
- **Most modern smartphone** and tablet platforms have remote wiping and tracking built into the operating system.

Antivirus and Antimalware:

- Antivirus solutions are helpful controls **against common malware types**.
- New mobile solutions use **behavioral analytics and signaling back to a remote cloud server** to analyze malware.

Transmission security:

- Majority of smartphones can use **multiple network mechanisms**.
- **For example, Wi-Fi**, **Bluetooth**, **provider network** (3G, 4G, CDMA, GSM, LTE, etc.), etc.
- **It is advisable to disable wireless access** when not in use to prevent unauthorized access to the device.

# Technical Controls …

Mobile usage control:

- Usage control will **allow users to turn off features with the aim to limit security attacks**.
- **For example, features for downloading** videos or images, texting, premium call numbers, overseas calls, and Internet access.
- **Content filtering controls can block certain websites** to allow **safer mobile browsing** on the Internet.
- **Location and monitoring settings** can help a user to limit sharing of private info publicly.
- **Control access to SIM cards and removable storage** such as SD card and internal storage.
- When replacing old mobile device with a new one, it is important to **consider deleting all personal information** from SIM, removable storage, and internal storage.

# Mobile Security Principles

Security principles

- High-level principles to provide a **structure for safer use thereby minimize the security risk of mobile devices**:
- Principles for mobile device **end-users**.
- Principles for mobile application **software developers**.

# Principles …

Principles for mobile device end-users:

- **Lock** the mobile device- ensure the use of **strong passphrases** and **never write down** and store within the device.
- **Accept and install the updates** (unless it is a fake security update).

  **Keep the operating system fully updated** to the latest version available from the vendor.

  **If the vendor ceased** supporting operating system updates, **upgrade the device**.

  **Ensure software updates**, in general, for **all applications**.
- Keep a **clean machine by removing** old, unused apps.
- Protect personal information by **storing the least amount possible** on devices.
- Wipe the data on the mobile device **before disposing it**.
- **Sync or backup your mobile device** to avoid the risk of lost or stolen devices.
- Stay safe behind bars (**do not jailbreak or root the device**) and **install apps from primary distribution** sources only- use Apple Store, Google Play, etc.
- Educate **yourself on best practices** regarding mobile devices.
- Use **malware detection software** which predicts and stops mobile attacks .
- Use **privacy apps** to explain all access to the data that installed apps require.
- **Avoid questionable apps** and be aware of apps that want to access your data.
- **Only attach your mobile device** to a trusted computer.
- When **charging mobile devices**, only connect to a trusted computer.

# Principles …

Principles for mobile application **developers**:

- The **architecture should be flexible and robust** enough to support devices, apps, and any back-end infrastructure and associated networks.
- Developers should undertake mobile **security awareness training**.
- Building security and privacy into every **phase of development**.
- Ensure that sensitive data is protected **in transit**.
- Ensure security and privacy by design like **locking down the security and privacy settings** of mobile apps by default.

# Class activities:

1. Individual participation 1:
   Discussion questions via Mentimeter
2. Group activity:
   List of activities to be provided
3. Individual participation 2:
   Questions via Kahoot with from previous week
4. Working on Quiz
   From Week37

NB: Additional information about the activities yet to be provided in separate document.

# Topics for next week

- Secure REST based communication in mobile apps
- Threat modeling